



Incidentes de Ciberseguridad

Unidad de Trabajo 1

Prevención de Incidentes de
Ciberseguridad

Curso de Especialización en Ciberseguridad

Entornos de las Tecnologías de la Información

CIP César Manrique

Curso Académico 2024-2025

i Información del Módulo

Datos del Módulo

- Denominación:** Incidentes de Ciberseguridad
- Código:** 991NTA
- Duración:** 145 horas (4 horas semanales)
- Familia Profesional:** Informática y Comunicaciones
- Nivel:** Formación Profesional de Grado Superior

Resultado de Aprendizaje - RA1

RA1. Desarrolla planes de prevención y concienciación en ciberseguridad, estableciendo normas y medidas de protección.

Criterios de Evaluación:

- **CE a)** Se han definido los principios generales de la organización en materia de ciberseguridad.
- **CE b)** Se ha establecido una normativa de protección del puesto de trabajo.
- **CE c)** Se ha definido un plan de concienciación de ciberseguridad dirigido a los empleados.
- **CE d)** Se ha desarrollado el material necesario para llevar a cabo las acciones de concienciación.
- **CE e)** Se ha realizado una auditoría para verificar el cumplimiento del plan de prevención y concienciación.

Marco Normativo de Referencia

- **ISO/IEC 27001:2022** - Sistema de Gestión de Seguridad de la Información
- **ISO/IEC 27002:2022** - Controles de seguridad de la información
- **Real Decreto 311/2022** - Esquema Nacional de Seguridad (ENS)
- **Reglamento (UE) 2016/679** - RGPD
- **NIST SP 800-50** - Building an IT Security Awareness Program

Duración de la Unidad

- Horas totales:** 20 horas
- Trimestre:** Primero

Peso en la evaluación: 15% del módulo

Índice del Material

1.	Contenidos Teórico-Prácticos	5
1.1	Principios Generales de Ciberseguridad	
1.2	Normativa de Protección del Puesto de Trabajo	
1.3	Plan de Concienciación en Ciberseguridad	
1.4	Desarrollo de Material de Concienciación	
1.5	Auditoría del Plan de Prevención	
2.	Casos Prácticos y Ejercicios	
3.	Plantillas y Recursos	
4.	Referencias y Recursos	
5.	Evaluación	

1. Contenidos Teórico-Prácticos

1.1 Principios Generales de Ciberseguridad Organizacional

Objetivos de aprendizaje

- Comprender la importancia estratégica de la ciberseguridad
- Identificar los principios fundamentales que debe establecer una organización
- Conocer el papel de la dirección en la ciberseguridad

Los 7 Principios Fundamentales de Ciberseguridad Organizacional

1. Compromiso de la Dirección

La ciberseguridad debe ser prioridad a nivel ejecutivo. La Alta Dirección debe demostrar su liderazgo mediante:

- Asignación de recursos adecuados (económicos, humanos, tecnológicos)
- Liderazgo visible en materia de seguridad
- Aprobación y respaldo de políticas de seguridad
- Inclusión de la ciberseguridad en la estrategia empresarial

Marco normativo ISO/IEC 27001:2022

La cláusula 5.1 de ISO/IEC 27001:2022 establece que la Alta Dirección debe demostrar liderazgo y compromiso respecto al SGSI mediante:

- Asegurar que la política y objetivos de seguridad se establezcan
- Asegurar la integración de los requisitos del SGSI en los procesos de negocio
- Asegurar que los recursos necesarios estén disponibles
- Comunicar la importancia de una gestión efectiva de la seguridad

2. Gestión de Riesgos

La gestión de riesgos es un proceso continuo que implica:

- **Identificación de activos críticos:** Determinar qué información, sistemas y procesos son esenciales para el negocio
- **Evaluación continua de amenazas:** Monitorizar el panorama de amenazas y vulnerabilidades
- **Análisis de impacto en el negocio (BIA):** Evaluar las consecuencias de incidentes de seguridad
- **Tratamiento de riesgos:** Decidir estrategias (evitar, mitigar, transferir, aceptar)

✓ Buena práctica

Realizar evaluaciones de riesgos al menos anualmente y siempre que haya cambios significativos en la organización, tecnología o entorno de amenazas.

3. Defensa en Profundidad

El principio de defensa en profundidad (o defensa en capas) se basa en no confiar en un único control de seguridad. Implica:

- **Múltiples capas de seguridad:** Físicas, de red, de aplicación, de datos
- **No confiar en un único control:** Si una capa falla, otras capas proporcionan protección
- **Redundancia en controles críticos:** Sistemas de backup, rutas alternativas
- **Segmentación:** Dividir la red y sistemas en zonas con diferentes niveles de confianza

Ejemplo de defensa en profundidad:

1. **Perímetro físico:** Control de acceso al edificio
2. **Perímetro de red:** Firewall externo
3. **Red interna:** Segmentación de red, VLANs
4. **Sistemas:** Hardening, antivirus, EDR
5. **Aplicaciones:** WAF, autenticación multifactor
6. **Datos:** Cifrado, DLP
7. **Personas:** Formación, concienciación

4. Principio de Mínimo Privilegio

Cada usuario, proceso o sistema debe tener únicamente los permisos necesarios para realizar su función, nada más.

⚠ Riesgo común

Uno de los errores más frecuentes es mantener cuentas con privilegios elevados innecesariamente. Ejemplo: empleados con permisos de administrador "por si acaso".

Implementación del principio:

- Acceso solo a lo necesario para el trabajo
- Revisión periódica de permisos (trimestral o semestral)
- Segregación de funciones (nadie debe tener control completo de un proceso crítico)
- Uso de cuentas con privilegios solo cuando sea necesario
- Monitorización de uso de privilegios elevados

5. Concienciación y Formación

El factor humano es la primera línea de defensa. Según diversos estudios, entre el 85-95% de los incidentes de seguridad tienen un componente de error humano.

Componentes clave:

- **Formación continua:** No es suficiente con formación inicial

- **Cultura de seguridad:** La seguridad debe ser parte del ADN organizacional
- **Simulaciones prácticas:** Phishing simulado, ejercicios de respuesta a incidentes
- **Reconocimiento y reporte:** Fomentar que los empleados reporten incidentes sin miedo

6. Cumplimiento Normativo

Las organizaciones deben cumplir con la normativa aplicable en su sector y geografía:

- **RGPD:** Protección de datos personales (obligatorio UE)
- **ENS:** Esquema Nacional de Seguridad (obligatorio AAPP españolas)
- **ISO 27001:** Certificación internacional de SGSI
- **Normativa sectorial:** PCI-DSS (sector financiero), HIPAA (salud en EE.UU.), NIS2 (operadores esenciales), etc.

⚖️ Consecuencias del incumplimiento

RGPD: Multas de hasta 20 millones de euros o 4% de la facturación anual global.

ENS: Responsabilidades administrativas y posibles sanciones.

Código Penal: Delitos informáticos (Arts. 197-201).

7. Mejora Continua

La ciberseguridad no es un estado, sino un proceso continuo de mejora. Se basa en el ciclo PDCA (Plan-Do-Check-Act):

1. **Plan (Planificar):** Establecer objetivos, identificar riesgos, definir controles
2. **Do (Hacer):** Implementar los controles y procesos planificados
3. **Check (Verificar):** Monitorizar, medir, auditar
4. **Act (Actuar):** Tomar acciones correctivas y preventivas

Elementos de mejora continua:

- Lecciones aprendidas de incidentes
- Resultados de auditorías
- Evolución del panorama de amenazas
- Cambios tecnológicos y de negocio
- Feedback de empleados y stakeholders

Marco normativo y estándares de referencia

ISO/IEC 27001:2022 - Sistema de Gestión de Seguridad de la Información (SGSI)

Estándar internacional que establece los requisitos para implementar, mantener y mejorar un SGSI.

Estructura:

- **Cláusulas 4-10:** Requisitos del sistema de gestión
- **Anexo A:** 93 controles de seguridad organizados en 4 categorías:
 - Controles organizativos (37 controles)

- Controles de personas (8 controles)
- Controles físicos (14 controles)
- Controles tecnológicos (34 controles)

Certificación

ISO 27001 es certificable por organismos acreditados. La certificación tiene validez de 3 años con auditorías de seguimiento anuales.

Esquema Nacional de Seguridad (ENS) - Real Decreto 311/2022

Marco normativo español obligatorio para las Administraciones Públicas y recomendado para empresas privadas.

Categorías de sistemas:

Categoría	Impacto	Requisitos
BÁSICO	Bajo	Medidas de seguridad básicas
MEDIO	Medio	Medidas reforzadas + auditoría bienal
ALTO	Alto	Medidas avanzadas + auditoría anual

Recursos clave del CCN-CERT:

- **CCN-STIC 804:** Guía de Implantación de un SGSI
- **CCN-STIC 806:** Plan de Adecuación del ENS
- **CCN-STIC 807:** Criptología de Empleo en el ENS
- **CCN-STIC 808:** Verificación del Cumplimiento de las Medidas del ENS
- **CCN-STIC 825:** Esquema de Seguridad Muestra para Empresas

Herramientas del CCN-CERT

PILAR: Herramienta de autoevaluación del ENS <https://pilar.ccn-cert.cni.es>

INES: Herramienta de auditoría y certificación del ENS

NIST Cybersecurity Framework

Marco de referencia desarrollado por el Instituto Nacional de Estándares y Tecnología de EE.UU., adoptado internacionalmente.

5 Funciones principales:

1. **Identificar:** Comprender el contexto, activos, riesgos
2. **Proteger:** Implementar salvaguardas
3. **Detectar:** Identificar ocurrencia de eventos de ciberseguridad
4. **Responder:** Tomar acciones ante incidentes detectados
5. **Recuperar:** Restaurar capacidades y servicios

RGPD - Reglamento General de Protección de Datos

Reglamento (UE) 2016/679, obligatorio para organizaciones que traten datos personales de ciudadanos de la UE.

Artículos clave para seguridad:

- **Art. 32:** Seguridad del tratamiento (medidas técnicas y organizativas apropiadas)
- **Art. 33-34:** Notificación de violaciones de seguridad (72 horas a autoridad, sin demora a afectados)
- **Art. 25:** Protección de datos desde el diseño y por defecto (Privacy by Design/Default)
- **Art. 35:** Evaluación de impacto en protección de datos (EIPD)

1.2 Normativa de Protección del Puesto de Trabajo

La normativa de protección del puesto de trabajo establece los requisitos mínimos de seguridad que deben cumplir todos los puestos de trabajo para proteger la información y los sistemas de la organización.

Elementos de una Política de Puesto de Trabajo Seguro

Política de Escritorio Limpio (Clean Desk Policy)

Clean Desk Policy

Conjunto de medidas para minimizar el riesgo de acceso no autorizado a información sensible en el puesto de trabajo.

Requisitos obligatorios:

- No dejar documentos sensibles sobre el escritorio fuera del horario laboral
- Guardar documentos confidenciales en armarios con cerradura
- Bloqueo de pantalla al ausentarse (Win+L en Windows, Ctrl+Alt+L en Linux, Cmd+Ctrl+Q en macOS)
- No dejar contraseñas escritas visibles (ni en post-its ni en archivos sin protección)
- Destrucción segura de documentos mediante destructora de nivel P-4 mínimo (DIN 66399)

Referencia normativa

ISO 27002:2022 - Control 7.12: Clear desk and clear screen

ENS mp.per.2: Deberes y obligaciones del personal

Política de Contraseñas

Las contraseñas son la primera línea de defensa. Una política robusta debe incluir:

Requisito	Especificación	Justificación
Longitud mínima	12 caracteres	NIST SP 800-63B recomienda mínimo 8, mejores prácticas 12+
Complejidad	Mayúsculas + minúsculas + números + símbolos	Aumenta espacio de búsqueda ante ataques de fuerza bruta
Cambio periódico	Solo si hay indicios de compromiso	NIST ya no recomienda cambios periódicos sin causa
Reutilización	No reutilizar últimas 5 contraseñas	Evita patrones predecibles
Gestión	Uso de gestor corporativo	Facilita contraseñas únicas y complejas

🔑 Ejemplos de contraseñas

✓ Correctas:

- "MiP€rr0T0by!2024" (15 caracteres, todos los tipos)
- "C4s4*BL4nc4-Mar2025" (19 caracteres, frase memorable modificada)

✗ Incorrectas:

- "123456" (demasiado simple)
- "password" (palabra de diccionario)
- "nombre123" (patrón predecible)
- "empresa2024" (información pública + año)

📖 Referencias normativas

NIST SP 800-63B: Digital Identity Guidelines - Authentication and Lifecycle Management

ISO 27002:2022 - Control 5.17: Información de autenticación

ENS mp.acc.4: Proceso de gestión de contraseñas

Política de Uso de Dispositivos

Dispositivos corporativos obligatorios:

- **Dispositivos autorizados:** Solo equipos proporcionados y gestionados por IT
- **Software permitido:** Lista blanca de aplicaciones aprobadas
- **Actualizaciones obligatorias:** Automáticas o ventanas de mantenimiento programadas
- **Antivirus corporativo:** Siempre activo, no desinstalable por usuario
- **Cifrado de disco completo:** BitLocker (Windows), FileVault (macOS), LUKS (Linux)

Prohibiciones

- No desinstalar o deshabilitar antivirus
- No instalar software no autorizado
- No modificar configuraciones de seguridad
- No hacer jailbreak (iOS) o root (Android) a dispositivos corporativos

Política de Conexiones de Red

Acceso remoto seguro:

- **VPN obligatoria:** Para cualquier acceso desde fuera de la oficina
- **Prohibición de redes WiFi públicas sin VPN:** Cafeterías, aeropuertos, hoteles
- **Segmentación de red:** Separación de redes de producción, desarrollo, invitados
- **Autenticación multifactor (MFA):** Para acceso VPN y sistemas críticos

VPN corporativa

Toda conexión remota a recursos corporativos debe realizarse a través de la VPN corporativa. Esto asegura:

- Cifrado del tráfico (evita interceptación)
- Autenticación del usuario y dispositivo
- Control de acceso basado en políticas
- Registro y auditoría de conexiones

Política de Datos

Clasificación de información:

Nivel	Descripción	Ejemplos	Controles
PÚBLICA	Información que puede ser divulgada sin restricciones	Material marketing, información web pública	Sin restricciones especiales
INTERNA	Información de uso interno, no sensible	Políticas generales, organigramas	Acceso solo empleados
CONFIDENCIAL	Información sensible que requiere protección	Contratos, datos financieros, proyectos estratégicos	Acceso restringido, cifrado, auditoría
SECRETA	Información crítica que podría causar daño grave si se divulga	Propiedad intelectual clave, datos personales sensibles	Máximo nivel de protección, cifrado fuerte, acceso muy restringido

Requisitos por nivel:

- **Almacenamiento autorizado:** Solo en ubicaciones aprobadas (servidores corporativos, SharePoint,

etc.)

- **Compartición segura:** Cifrado en tránsito y en reposo, enlaces con expiración
- **Copias de seguridad:** Según criticidad, verificación de restauración
- **Retención y eliminación:** Según normativa aplicable (RGPD, sectorial)

Referencias normativas aplicables

Normativa de referencia

ISO/IEC 27002:2022:

- Control 5.15: Control de acceso
- Control 5.17: Información de autenticación
- Control 5.23: Seguridad de la información en el uso de servicios en la nube
- Control 6.2: Términos y condiciones del empleo
- Control 7.10: Monitoreo del almacenamiento
- Control 7.12: Clear desk and clear screen

ENS (Real Decreto 311/2022):

- mp.acc.4: Proceso de gestión de contraseñas
- mp.info.3: Cifrado
- mp.sw.2: Protección frente a código dañino
- mp.com.2: Protección de la confidencialidad
- mp.com.4: Segregación de redes

NIST:

- SP 800-63B: Digital Identity Guidelines (contraseñas)
- SP 800-46 Rev 2: Enterprise Telework and Remote Access Security
- SP 800-53 Rev 5: Security and Privacy Controls

CCN-STIC:

- 807: Criptología de Empleo en el ENS
- 817: Gestión de Ciberincidentes
- 825: Esquema de Seguridad Muestra para Empresas

1.3 Plan de Concienciación en Ciberseguridad

Un plan de concienciación efectivo es fundamental para reducir el riesgo asociado al factor humano, responsable del 85-95% de los incidentes de seguridad.

Estructura de un Plan de Concienciación

Fase 1: Análisis de Situación

- Evaluación del nivel actual de concienciación (encuestas, tests)
- Identificación de brechas de conocimiento
- Análisis de incidentes previos causados por factor humano
- Benchmarking con sector/tamaño similar

Fase 2: Definición de Objetivos SMART

🎯 **Objetivos SMART**

Specific (Específico): Claro y concreto

Measurable (Medible): Cuantificable

Achievable (Alcanzable): Realista

Relevant (Relevante): Alineado con objetivos de negocio

Time-bound (Temporal): Con plazo definido

Ejemplo de objetivo SMART:

"Reducir en un 50% los clics en emails de phishing simulado (de 20% a 10%) en un plazo de 6 meses, mediante formación mensual y simulaciones quincenales"

Fase 3: Público Objetivo y Segmentación

- **Dirección:** Enfoque en riesgos de negocio, cumplimiento, ROI
- **Empleados técnicos:** Contenido más profundo, amenazas avanzadas
- **Empleados administrativos:** Phishing, ingeniería social, uso seguro de herramientas
- **Personal externo/contratistas:** Normativas aplicables, canales de reporte

Fase 4: Contenidos y Mensajes Clave

Temas esenciales a cubrir:

- Phishing y ingeniería social
- Gestión de contraseñas
- Navegación segura
- Uso de dispositivos móviles
- Teletrabajo seguro
- Protección de datos personales (RGPD)

- Reporte de incidentes

Fase 5: Metodologías y Herramientas

Metodología	Ventajas	Frecuencia recomendada
Sesiones presenciales/online	Interacción, Q&A, adaptación	Trimestral
E-learning	Escalable, autónomo, medible	Anual obligatorio + opcional continuo
Campañas de email	Recordatorios, refuerzo	Mensual
Pósters y cartelería	Presencia visual constante	Permanente, rotación trimestral
Simulaciones de phishing	Práctica real, métrica efectiva	Mensual o quincenal
Gamificación	Engagement, diversión, competición	Trimestral (eventos)

Fase 6: Calendario de Ejecución

- **Formación inicial (onboarding):** Primera semana de incorporación
- **Formación anual obligatoria:** Todos los empleados, renovación conocimientos
- **Píldoras mensuales:** Temas específicos, 5-10 minutos
- **Campañas trimestrales específicas:** Enfoque en amenaza o tema concreto

Fase 7: Métricas y Seguimiento

KPIs esenciales:

KPI	Objetivo	Frecuencia medición
Tasa de finalización de formaciones	> 95%	Mensual
Resultados de tests	> 80% aprobados	Por formación
Tasa de clics en phishing simulado	< 10%	Por simulación
Tasa de reporte de phishing	> 30%	Por simulación
Número de incidentes por factor humano	Tendencia decreciente	Mensual
Tiempo medio de reporte de incidentes	< 2 horas	Por incidente

Referencias metodológicas

- **NIST SP 800-50:** Building an IT Security Awareness and Training Program
- **ENISA:** Cyber Security Culture Guidelines: Behavioural Aspects
- **ISO/IEC 27001:2022 - Control A.6.3:** Concienciación, educación y formación
- **CCN-STIC 825:** Esquema de Seguridad Muestra para Empresas

1.4 Desarrollo de Material de Concienciación

El material de concienciación debe ser atractivo, claro, relevante y efectivo para lograr cambios de comportamiento.

Tipos de Materiales

A. Materiales Formativos

- Presentaciones interactivas
- Vídeos formativos (2-5 minutos)
- Infografías
- Guías rápidas (1 página)
- FAQs

B. Materiales de Refuerzo

- Pósters para oficina (A3)
- Salvapantallas
- Firmas de email con mensajes de seguridad
- Protectores de webcam con mensajes
- Adhesivos para portátiles

C. Materiales de Evaluación

- Tests de conocimientos
- Simulaciones de phishing
- Ejercicios prácticos
- Escape rooms virtuales

Principios de Diseño de Material Efectivo

Principio	Descripción	Ejemplo
✓ Claridad	Mensaje directo y comprensible	"Si dudas, NO hagas clic"
✓ Brevedad	Contenido conciso (atención limitada)	Vídeos < 3 min, pósters con máximo 3 mensajes
✓ Visual	Uso de imágenes, iconos, colores	Iconos 🚫🔒⚠️ en lugar de solo texto
✓ Relevancia	Aplicable al día a día del empleado	Ejemplos de emails de phishing reales recibidos
✓ Práctica	Incluir acciones concretas	"Reportar a: seguridad@empresa.com"
✓ Frecuencia	Exposición repetida al mensaje	Mismos mensajes en diferentes formatos

Recursos para crear material

🌸 Herramientas de diseño

- **Canva:** <https://www.canva.com> - Plantillas de pósters, infografías
- **Genially:** <https://genial.ly> - Presentaciones interactivas
- **Piktochart:** <https://piktochart.com> - Infografías
- **Adobe Express:** <https://www.adobe.com/express/> - Diseño rápido

↓ Bancos de recursos gratuitos

Recursos oficiales:

- **INCIBE - Material de sensibilización:** <https://www.incibe.es/empresas/herramientas/material-sensibilizacion>
- **OSI - Oficina de Seguridad del Internauta:** <https://www.osi.es>
- **CCN-CERT - Avisos de seguridad:** <https://www.ccn-cert.cni.es>
- **AEPD - Recursos RGPD:** <https://www.aepd.es>

Iconos y elementos visuales:

- **Flaticon:** <https://www.flaticon.com> - Iconos de seguridad
- **Font Awesome:** <https://fontawesome.com> - Iconografía
- **Unsplash:** <https://unsplash.com> - Imágenes libres

Ejemplos de Mensajes Clave

Sobre Phishing

 ANTES DE HACER CLIC, PIENSA:

- ✓ ¿Esperaba este correo?
- ✓ ¿Conozco al remitente?
- ✓ ¿El enlace parece sospechoso?
- ✓ ¿Pide urgencia o datos sensibles?

 SI DUDAS, NO HAGAS CLIC → Contacta con IT

Sobre Contraseñas

 CONTRASEÑA FUERTE:

- ✓ Mínimo 12 caracteres
- ✓ Mayúsculas + minúsculas + números + símbolos
- ✓ Única para cada servicio
- ✓ Usa el gestor corporativo

✗ NUNCA: "123456", "password", tu nombre

1.5 Auditoría del Plan de Prevención y Concienciación

La auditoría permite verificar la efectividad del plan de prevención y concienciación, identificar brechas y proponer mejoras.

Tipos de Auditoría

Auditoría de Cumplimiento Documental

- Verificar existencia de políticas y procedimientos
- Revisar aprobaciones y firmas
- Comprobar actualizaciones (¿están vigentes?)
- Verificar comunicación y difusión

Auditoría de Implementación Técnica

- Verificar controles técnicos (cifrado, antivirus, etc.)
- Comprobar configuraciones de seguridad
- Revisar logs de seguridad
- Pruebas de penetración (opcional)

Auditoría de Concienciación

- Evaluar nivel de conocimiento (tests, encuestas)
- Simular ataques de phishing
- Entrevistas con empleados
- Observación de prácticas (escritorio limpio, bloqueo de pantalla)

Proceso de Auditoría

1. Planificación

- Definir alcance (qué se va a auditar)
- Seleccionar muestra (si no es censo completo)
- Preparar checklist de verificación
- Programar actividades y asignar recursos

2. Ejecución

- Revisión documental
- Entrevistas con responsables y empleados
- Observaciones in situ
- Pruebas técnicas
- Simulaciones (phishing, incidentes)

3. Análisis

- Identificar no conformidades
- Clasificar hallazgos por severidad
- Evaluar nivel de riesgo
- Determinar causas raíz

4. Informe

Estructura del informe de auditoría:

- 1. Resumen ejecutivo** (1-2 páginas)
 - Objetivo y alcance
 - Metodología
 - Conclusiones principales
 - Nivel de madurez general
- 2. Hallazgos detallados**
 - Descripción del hallazgo
 - Evidencias (capturas, logs, testimonios)
 - Impacto y riesgo
 - Recomendación
- 3. Evaluación del nivel de madurez** (escala 1-5)
- 4. Recomendaciones priorizadas**
- 5. Plan de acción propuesto**

5. Seguimiento

- Verificar implementación de mejoras
- Re-auditoría (si es necesario)
- Actualización de documentación

Clasificación de Hallazgos

Severidad	Descripción	Plazo de resolución
● CRÍTICO	Vulnerabilidad que puede ser explotada inmediatamente con alto impacto	< 7 días
● ALTO	Incumplimiento grave que expone a riesgo significativo	< 30 días
● MEDIO	Incumplimiento que podría derivar en incidente	< 90 días
● BAJO	Oportunidad de mejora, incumplimiento menor	< 180 días

Referencias para auditorías

- **ISO/IEC 27007:2020:** Directrices para la auditoría de SGSI
- **ISO 19011:2018:** Directrices para la auditoría de sistemas de gestión
- **ENS - Real Decreto 311/2022, Arts. 35-37:** Auditoría de la seguridad
- **CCN-STIC 802:** Guía de Auditoría del ENS
- **CCN-STIC 804:** Guía de Implantación de un SGSI

Herramientas de auditoría

- **PILAR:** Herramienta de autoevaluación del ENS <https://pilar.ccn-cert.cni.es>
- **INES:** Herramienta de auditoría del ENS (CCN-CERT)
- **Lynis:** Auditoría de seguridad para Unix/Linux <https://cisofy.com/lynis>
- **OpenVAS:** Escáner de vulnerabilidades <https://www.openvas.org>

Checklist de Auditoría (Ejemplo)

Lista de verificación para auditoría de RA1:

☐	Ítem a verificar	Referencia
☐	Existe política de ciberseguridad aprobada por Dirección	ISO 27001 - 5.2
☐	Política actualizada en últimos 12 meses	ISO 27001 - 9.3
☐	Normativa de puesto de trabajo documentada y difundida	ISO 27001 - A.6.2.1
☐	100% empleados firmaron aceptación de normativa	ISO 27002 - 6.2
☐	Existe plan de concienciación documentado	ISO 27001 - A.6.3
☐	Formación inicial impartida a nuevos empleados	NIST SP 800-50
☐	Formación anual realizada (> 80% participación)	ISO 27001 - A.6.3
☐	Simulaciones de phishing realizadas trimestralmente	Buena práctica
☐	Tasa de clic en phishing < 10%	KPI objetivo
☐	Tasa de reporte de phishing > 30%	KPI objetivo
☐	Cifrado de disco implementado en todos los equipos	ENS

☐	Estado de disco implementado en todos los equipos	mp.info.3
☐	Política de contraseñas cumplida (complejidad mínima)	ENS mp.acc.4
☐	Bloqueo automático configurado (≤ 5 min)	ENS mp.acc.4
☐	Antivirus actualizado en todos los equipos	ENS mp.sw.2
☐	VPN corporativa para acceso remoto	ENS mp.com.2
☐	MFA implementado para accesos críticos	ISO 27002 - 5.17
☐	Material de concienciación visible en oficinas	Buena práctica
☐	Canal de reporte de incidentes definido y comunicado	ISO 27001 - A.5.24
☐	Registro de incidentes mantenido	ISO 27001 - A.5.26
☐	Auditoría de seguridad realizada en último año	ENS Art. 35

2. Casos Prácticos y Ejercicios

Esta sección incluye 6 ejercicios prácticos diseñados para aplicar los conocimientos teóricos adquiridos. Cada ejercicio está basado en situaciones reales y requiere la consulta de las referencias normativas proporcionadas.

EJERCICIO 1: Definición de Principios de Ciberseguridad

Contexto: Eres el recién nombrado Responsable de Seguridad de "TechSolutions S.L.", una empresa de desarrollo de software con 150 empleados. La dirección ha decidido tomar en serio la ciberseguridad tras un incidente reciente de ransomware.

Tarea: Redacta un documento (2-3 páginas) que establezca los Principios Generales de Ciberseguridad de la organización.

Debe incluir:

1. Introducción (compromiso de la dirección)
2. 5-7 Principios fundamentales claramente definidos
3. Responsabilidades por roles
4. Declaración de aplicabilidad
5. Proceso de actualización

Criterios de evaluación: Claridad (20%), Pertinencia de principios (30%), Definición de responsabilidades (20%), Alineación con estándares (20%), Viabilidad (10%)

EJERCICIO 2: Normativa de Puesto de Trabajo

Contexto: "FinanzasSeguras S.A." (sector financiero, 80 empleados, trabajo híbrido) necesita establecer una normativa de protección del puesto de trabajo que cumpla con requisitos del Banco de España y el ENS (categoría MEDIA).

Tarea: Desarrolla una Normativa de Protección del Puesto de Trabajo completa (5-7 páginas).

i Ejercicios adicionales

Los ejercicios 3-6 incluyen:

- **Ejercicio 3:** Plan Anual de Concienciación
- **Ejercicio 4:** Creación de Kit de Concienciación
- **Ejercicio 5:** Simulación de Campaña de Phishing
- **Ejercicio 6:** Auditoría de Cumplimiento

Consulta el material educativo completo para ver los enunciados detallados de cada ejercicio.

3. Plantillas y Recursos

Esta sección proporciona plantillas profesionales listas para usar o adaptar:

Plantillas Disponibles

- **Plantilla 1:** Documento de Principios de Ciberseguridad
- **Plantilla 2:** Normativa de Puesto de Trabajo
- **Plantilla 3:** Plan Anual de Concienciación
- **Plantilla 4:** Informe de Auditoría

↓ Acceso a plantillas

Las plantillas completas están disponibles en el material educativo original en formato editable (Markdown/Word).

Todas las plantillas están alineadas con:

- ISO/IEC 27001:2022
- Real Decreto 311/2022 (ENS)
- NIST SP 800-50
- RGPD (UE) 2016/679

4. Referencias y Recursos Oficiales y No Oficiales

Esta sección extensa incluye más de 90 recursos organizados en categorías:

4.1 Normativa y Estándares Oficiales

Normas ISO

1. **ISO/IEC 27001:2022** - Sistemas de Gestión de Seguridad de la Información
<https://www.iso.org/standard/27001>
2. **ISO/IEC 27002:2022** - Controles de seguridad de la información
<https://www.iso.org/standard/75652.html>

Legislación y Normativa Española

6. **Real Decreto 311/2022** - Esquema Nacional de Seguridad (ENS)
Portal ENS: <https://ens.ccn.cni.es>
BOE: <https://www.boe.es/eli/es/rd/2022/05/03/311>
7. **Reglamento (UE) 2016/679** - RGPD
<https://www.boe.es/doue/2016/119/L00001-00088.pdf>

4.2 Organismos Oficiales Españoles

CCN-CERT

21. **CCN-CERT** - Centro Criptológico Nacional
Portal: <https://www.ccn-cert.cni.es>
Avisos: [avisos-ccn-cert](#)
Email: avisos@ccn-cert.cni.es

INCIBE

22. **INCIBE** - Instituto Nacional de Ciberseguridad
Portal principal: <https://www.incibe.es>
Empresas: <https://www.incibe.es/empresas>
Línea 017: Para empresas y ciudadanos
Email incidentes: incidentes@incibe.es

OSI

23. **OSI** - Oficina de Seguridad del Internauta
Portal: <https://www.osi.es>
Twitter: @osiseguridad

AEPD

24. AEPD - Agencia Española de Protección de Datos

Portal: <https://www.aepd.es>

Canal prioritario (brechas): <https://www.aepd.es/es/canalprioritario>

4.3 Organismos Internacionales

28. ENISA - European Union Agency for Cybersecurity

<https://www.enisa.europa.eu>

29. CISA - Cybersecurity & Infrastructure Security Agency (EE.UU.)

<https://www.cisa.gov>

Recursos completos

La lista completa de referencias incluye más de 90 recursos organizados en:

- Normativa y estándares oficiales (20 referencias)
- Organismos oficiales españoles (5 referencias)
- Organismos internacionales (10 referencias)
- Recursos no oficiales de calidad (35 referencias)
- Herramientas prácticas (15 referencias)
- Certificaciones profesionales (5 referencias)
- Bibliografía recomendada (10 referencias)

Consulta el material educativo completo para acceder a todas las referencias con sus URLs.

5. Evaluación

5.1 Rúbrica de Evaluación - RA1

Criterio	Insuficiente (0-4)	Suficiente (5-6)	Bien (7-8)	Notable-Excelente (9-10)	Peso
CE a) Principios	No define o son inadecuados	Define principios básicos pero incompletos	Define principios adecuados y coherentes	Define principios completos, alineados con estándares	15%
CE b) Normativa	Normativa inexistente o muy deficiente	Normativa básica con elementos principales	Normativa completa y bien estructurada	Normativa completa, específica, profesional y alineada con ENS/ISO	20%
CE c) Plan	Plan inexistente o inadecuado	Plan básico con elementos esenciales	Plan bien estructurado y realista	Plan completo, detallado, con métricas y basado en NIST SP 800-50	25%
CE d) Material	Material inexistente o de muy baja calidad	Material básico funcional	Material de buena calidad y aplicable	Material excelente, atractivo, efectivo, profesional	20%
CE e) Auditoría	No realiza o totalmente inadecuada	Auditoría básica con elementos principales	Auditoría completa y bien estructurada	Auditoría exhaustiva, profesional, conforme ISO 27007	20%

5.2 Prueba Objetiva Teórica - RA1

Instrucciones

Duración: 30 minutos

Formato: 20 preguntas de opción múltiple

Puntuación: Cada respuesta correcta: 0,5 puntos. Respuestas incorrectas no penalizan.

Calificación: Nota final = (aciertos × 0.5) × 10 / 10 puntos totales

Ejemplo de pregunta:

1. ¿Cuál de los siguientes NO es uno de los principios fundamentales de ciberseguridad organizacional?

- a. Compromiso de la Dirección
- b. Gestión de Riesgos
- c. Máximo Privilegio
- d. Defensa en Profundidad

Respuesta correcta: c) Máximo Privilegio (el principio correcto es Mínimo Privilegio)

Prueba completa

La prueba objetiva completa con 20 preguntas y respuestas se encuentra en el material educativo original.

5.3 Criterios de Calificación Final

La calificación final de la UT1 se compone de:

- **60%:** Pruebas objetivas teórico-prácticas (tests y supuestos)
- **40%:** Actividades y ejercicios prácticos

! Requisitos de aprobado

Para aprobar la UT1:

- Nota ≥ 5 en pruebas objetivas (60%)
- Nota ≥ 5 en actividades prácticas (40%)
- Entrega de al menos 80% de las actividades propuestas

Se deben aprobar ambas partes por separado. No se hace media si alguna parte está suspensa.